

CCSP D5 安全維運

CCSP flashcards for Knowt. 32 cards. Upload this PDF to AI PDF Summarizer.

Q001 日誌跨系統關聯的第一先決條件是什麼？

A Clock synchronization / NTP。不是 RAM 或磁碟容量。

Q002 Honeypot 的合法用途有哪些？

A 偵測、分流注意力、拖延、蒐集威脅情報。

Q003 Honeypot 不能做什麼？

A 主動招攬攻擊者 (luring)。那可能構成 entrapment，傷害後續追訴。

Q004 雲端自動修補最大死角是什麼？

A Snapshot / saved / dormant VM images 收不到 patch，被喚醒後帶已知漏洞上線。

Q005 Baseline 發揮完整價值的必要條件？

A Documentation。沒寫下來就無法定義、證明與還原偏離。

Q006 Baseline 是防毒或 HIDS 嗎？

A 不是。它是用來比較的安全組態標準。

Q007 發現 baseline deviation 應該直接改回去嗎？

A 不要。應 document → assess → authorize 或 remediate → 若屬合法變更則更新 baseline。

Q008 Configuration maintenance 包含什麼？不包含什麼？

A 包含 baseline、變更、patch、版本控制、驗證、偏離管理、文件。不包含 social engineering。

Q009 Production patch 為什麼不能看到更新就部署？

A 要評估 compatibility、可用性衝擊與變更風險：Identify → Evaluate → Test → Approve → Deploy → Validate。

Q010 Vendor guidance 能否取代 risk owner ?

A 不能。Vendor 建議重要，但風險所有者仍是你的組織。

Q011 Host 進入 maintenance 前，cluster 通常先做什麼？

A Move / drain workload，或確保其他節點仍能承載服務。

Q012 Maintenance mode 可以停 monitoring / logging 嗎？

A 不行。維護期間仍要保留監控與日誌，才能驗證與調查。

Q013 維運生命週期口訣？

A Baseline → Harden → Document → Monitor → Detect deviation → Change management → Patch / test → Remediate → Re-baseline。

Q014 Exposure Factor 受什麼影響最大？

A Type of threat vector。它決定破壞機制與可能損失百分比。

Q015 SLE 與 ALE 公式？

A $SLE = AV \times EF$; $ALE = SLE \times ARO$ 。

Q016 Risk treatment 四種？

A Avoid、mitigate、transfer / share、accept。殘餘風險最終必須被適當接受。

Q017 ITIL 是什麼？

A IT service management 框架。不要當成資安控制目錄或法律。

Q018 COBIT 偏向什麼？

A IT 治理與控制目標，不是單純技術組態基準。

Q019 Golden image 為何是修補風險？

A 映像檔若過期，之後大量克隆會複製未修補狀態。

Q020 跨時區 VM patching 要注意什麼？

A 維護窗必須對應各系統本地風險與業務時間，不能只用單一總部時區硬切。

Q021 Hardening 與 auditing 差在哪？

A Hardening 是減少攻擊面的強化；auditing 是驗證與舉證。不要把稽核當強化本身。

Q022 Management plane isolation 的維運意義？

A 管理面被攻破可控制所有 guest；應獨立網路、強認證與嚴格存取。

Q023 HA、clustering、live migration 怎麼分？

A HA 是整體可用性目標；clustering 提供節點互相承接；live migration 是把運行中 workload 挪走以便維護。

Q024 為什麼離線就等於可能未修補？

A 自動化修補通常只打到 running instance。

Q025 Configuration drift 沒有文件時為何無法證明？

A 沒有基準就無法證明「現在」偏離「應有狀態」。

Q026 定量風險裡 AV、EF、ARO 各是什麼？

A AV 資產價值；EF 單次事件損失比例；ARO 年發生率。

Q027 殘餘風險最後要誰處理？

A 必須被適當的管理層接受，或繼續處理到可接受。不能懸空。

Q028 SIEM 的價值建立在什麼前提？

A 可靠、同步、集中的日誌。沒有時間同步就很難做事件重建。

Q029 Patch 責任在共享責任模型裡怎麼想？

A 誰能改那一層誰就有操作責任：guest OS / app 常是客戶；底層 hypervisor / host 常是 CSP。

Q030 Honeypot EXCEPT 題秒選什麼？

A Luring attackers。

Q031 問 baseline 必要條件時不要選什麼？

A 不要選培訓或 HIDS；選 documentation。

Q032 維護完成後還缺哪一步？

A Validate 後 return to service，必要時更新 baseline。